

Microsoft Foundry Agent 托管部署与测试

版本：v1.0
示例应用：xAgent

目录与快速入口

我想做什么	直接跳转
了解整体架构与组件职责	总体架构
为已有 MAF Agent 选择并实现托管协议	Hosting 接入检查
部署前验证 Hosting 兼容性	本地 Hosting 验证
部署并调用 Hosted Agent	托管部署
执行 Agent Prompt Smoke Test	Prompt 测试
执行批量质量与安全评估	Evaluation
查看 Agent Session 日志	Hosted Session 日志
查看 Foundry Trace 与 Span	Foundry Portal Trace
查看 Monitor 指标与告警	Agent Monitoring Dashboard
配置并验证 Guardrails	Guardrails
执行性能与负载测试	性能测试
删除实验资源	清理

1. 阅读目标

阅读并实践本手册后，读者应能够：

1. 解释 Agent Framework、Foundry Project、模型部署与 Hosted Agent 的职责边界；
2. 根据调用场景选择 Responses 或 Invocations，并实现对应的 Hosted Agent 协议服务；
3. 理解 azd provision、Hosting 兼容性验证和托管部署的生命周期；
4. 调用预先部署的 Hosted Agent，并验证版本、状态和 endpoint；
5. 使用 Portal/CLI 查看 Evaluation、日志、Trace 和 Monitor；
6. 理解 Guardrail、身份权限、安全测试和资源清理要求。

2. 内容范围

本手册假设已有 MAF Agent 已完成业务开发和本地功能测试。内容从 Hosting 接入开始，覆盖 Foundry Project、模型部署、Hosted Agent Direct Code Deployment、Responses Protocol、远程 smoke test、Evaluation、Trace、Monitor、Guardrails 和性能测试。

本手册不覆盖 Agent 业务逻辑重写、Prompt 设计基础、Tool/Workflow 开发、业务数据、生产数据库、真实客户名称、生产密钥和生产网络连接。

2.1 接入前提

开始前，现有 Agent 应满足：

1. 使用 Microsoft Agent Framework，并能在本地完成核心业务流程；
2. Agent、Tool 和 Workflow 已有自己的单元测试或 smoke test；
3. 依赖可通过 requirements.txt 或等价清单安装；
4. 配置通过环境变量或 Managed Identity 注入，不依赖硬编码密钥；
5. 已明确 Foundry 托管后需要访问的模型、Tool、网络和数据边界。

2.2 使用方式

本手册可按目录顺序阅读，也可从首页按任务直接跳转。以下操作耗时较长，建议在自己的非生产环境中按需执行：

- Foundry Account、Project 和模型首次 Provision；
- Hosted Agent 首次远程构建；
- 完整 Evaluation、负载测试和 AI Red Teaming Scan；
- Private Endpoint、生产网络和业务 Tool 集成。

每个章节同时给出背景、命令和验收条件。只想查询日志、Trace、Prompt 测试或性能测试时，可直接打开对应章节，无需从头执行全部步骤。

3. 总体架构

```

已有 MAF Agent (Agent / Tool / Workflow / 业务指令)
├─ 增加 Foundry Hosting 接入层
├─ 选择协议：Responses / Invocations
├─ 本 Lab：ResponsesHostServer
│   └─ requirements.txt
│   └─ azure.yaml
├─ 本地 Hosting 兼容性验证
├─ azd deploy
│   └─ Microsoft Foundry Project
│       ├── Hosted Agent: ${AGENT_NAME}
│       ├── Model deployment: ${MODEL_DEPLOYMENT_NAME}
│       ├── Agent version and endpoint
│       └─ Session / conversation / logs / evaluation

```

3.1 组件职责

组件	职责
现有 MAF Agent	保留已有的 Agent、Tool、Workflow、Prompt 和业务测试
FoundryChatClient	使用 Project endpoint 和模型部署调用模型
协议服务	实现声明的 Responses、Invocations 或其他受支持协议
ResponsesHostServer	MAF 的 Responses 协议适配器；是本 Lab 选型，不是 Foundry 的唯一实现
azure.yaml	声明模型、Hosted Agent、运行时、入口和资源规格
azd	管理初始化、Provision、Run、Deploy、Invoke 和 Eval
Foundry Project	管理 Agent、模型连接、版本、会话和评估上下文
Hosted Agent	在 Foundry 托管运行时执行自定义 Agent 代码

3.2 MAF 与 Foundry 托管架构

xAgent 仅作为 Microsoft Agent Framework (MAF) Hosting 接入样例，无需复制其业务指令。应将自己的 Agent 实例交给 Foundry Hosting Adapter，并保留原有 Tool、Workflow 和业务测试。

架构要素	xAgent 实现	职责
核心 Agent 类型	from agent_framework import Agent	Agent 的编排和执行主体来自 MAF
Foundry 模型客户端	from agent_framework.foundry import FoundryChatClient	MAF 通过 Foundry Project 调用模型
运行依赖	agent-framework-foundry	使用 MAF Foundry 集成包
Hosting 适配	agent-framework-foundry-hosting	为 MAF 提供 Foundry Hosting 协议适配
协议服务器	ResponsesHostServer(agent)	本 Lab 用它实现 Responses Protocol; 它不是所有 Hosted Agent 的强制类

调用链为：

```

Foundry Responses Endpoint
-> ResponsesHostServer
-> MAF Agent
-> MAF FoundryChatClient
-> Foundry Project model deployment

```

MAF 负责 Agent 代码与 workflow；Foundry 负责托管、版本、身份、endpoint、Session、Guardrails、Trace 和 Evaluation。

4. 实验环境与动态资源发现

Azure 资源名称由使用者自己的 azd environment、资源组和唯一后缀决定。

如果尚未创建 Foundry Project、模型部署和资源组，请先完成第 8 节：创建 Foundry 资源。Provision 必须在克隆仓库后的项目根目录执行，也就是能够看到 azure.yaml、README.md、infra 和 src 的目录；不要在 docs 或 src/agent-framework-agent-basic-responses 目录中执行。

如果资源已经存在，并且当前终端已选择对应的 azd environment，则在项目根目录执行：

```

$ctx = .\scripts\get-lab-context.ps1
$ctx | Format-List

```

后续命令统一使用 \$ctx，不复制其他环境的资源名称。

项目	动态值
Resource Group	\$ctx.ResourceGroup
Azure Region	\$ctx.Location
Foundry Account	\$ctx.FoundryAccountName
Foundry Project	\$ctx.FoundryProjectName
Model deployment	\$ctx.ModelDeploymentName
Hosted Agent	\$ctx.AgentName
Agent version/status	\$ctx.AgentVersion / \$ctx.AgentStatus
Runtime	Python 3.13
Protocol	Responses 2.0
Deployment	Direct code, remote dependency build
Application Insights	\$ctx.ApplicationInsightsName
Log Analytics	\$ctx.LogAnalyticsName
Guardrail resource ID	\$ctx.RaiPolicyId

资源尚未创建时，对应属性为空。实际资源名称只记录在本地测试证据中，不写入通用参考步骤。

5. 建议阅读路径

目标	建议章节
理解技术架构	第 3、6、7 节
将现有 MAF Agent 接入并托管	第 7、8、9、10 节
验证 Prompt 与 Agent 质量	第 11 节
查询日志、Trace 与 Monitor	第 12 节
配置安全、Guardrails 与性能测试	第 13 节
核对实现并清理资源	第 14、15、16 节

6. Agent 生命周期

6.1 Provision 与 Deploy

操作	处理对象	是否生成 Agent 版本
azd provision	Resource Group、Foundry Account/Project、模型部署	否
azd ai agent run	本地进程和本地 endpoint	否
azd deploy	Hosted Agent 代码和运行配置	是
azd ai agent endpoint update	Endpoint/Card 配置	通常不生成代码版本

不要把基础设施创建与 Agent 代码部署混为同一步。

6.2 Prompt Agent 与 Hosted Agent

类型	适用场景	部署方式
Prompt Agent	模型、指令和平台 Tool，无自定义运行代码	Foundry Agent API/MCP
Hosted Agent	Python/.NET 代码、自定义 Tool、复杂依赖和 Workflow	azd deploy

xAgent 采用 Hosted Agent，支持 Python 自定义代码、依赖管理、版本化部署和托管运行。

7. 为现有 MAF Agent 增加 Foundry Hosting 协议层

7.1 先选择协议

Foundry Hosted Agent 的要求是：代码必须实现并声明所选协议，而不是必须使用 ResponsesHostServer。

场景	建议协议	服务实现
对话、RAG、Tool、多轮历史和 OpenAI-compatible client	Responses	可使用 MAF ResponsesHostServer 或其他兼容实现
Webhook、任意 JSON、非对话处理或自定义 SSE	Invocations	使用 Invocations 协议库或兼容实现
同时需要标准对话和自定义入口	Responses + Invocations	在同一 Hosted Agent 中声明并实现两个协议

本 Lab 的 azure.yaml 声明 Responses 2.0, 因此代码必须暴露兼容 Responses 的服务。对 MAF Agent, ResponsesHostServer 是最直接的官方适配器, 还负责 HTTP Server、健康检查和 OpenTelemetry 集成, 所以本 Lab 推荐使用它。若改用 Invocations 或其他兼容库, 必须同步修改代码、azure.yaml 协议声明、本地调用和测试方式。

7.2 本 Lab 的 Responses 接入

接入时不重写 Agent 业务逻辑, 只增加一个薄的 Responses Hosting 入口。参考 main.py 完成四件事:

- 1. 从环境读取 Project endpoint 和模型部署名;
- 2. 使用 DefaultAzureCredential 获取当前身份;
- 3. 创建或导入现有 MAF Agent;
- 4. 将 Agent 交给 ResponsesHostServer 启动协议服务。

xAgent 示例使用 FoundryChatClient, 但这不是 Hosting Adapter 的强制要求。如果现有 Agent 已使用其他 MAF 模型客户端, 可以保留原客户端; 必须确认其 endpoint、身份凭据、网络访问和配置在 Hosted Agent 运行环境中同样可用。

核心接入形态应接近:

```
from agent_framework_foundry_hosting import ResponsesHostServer
from my_agent import create_agent

agent = create_agent()
ResponsesHostServer(agent).run()
```

create_agent() 代表已有实现。不要把现有 Tool、Workflow 和 Prompt 搬进 xAgent 示例指令, 也不要为了托管而复制业务代码。

7.3 Hosting 接入检查清单

检查项	要求
Agent 实例	能由入口模块稳定创建, 启动时不执行交互式输入
协议一致性	代码实现必须与 azure.yaml 声明的协议和版本一致
Responses 选型	使用 ResponsesHostServer(agent) 或其他兼容实现暴露 Responses Protocol
入口	azure.yaml 的 entryPoint 指向实际入口文件
依赖	所有运行依赖都在部署依赖清单中, 不依赖本机全局包
配置	endpoint、模型名和 Tool 配置来自环境变量或外部配置
身份	本地使用开发身份, 托管使用 Managed Identity/RBAC
状态	多副本环境不依赖进程内全局会话状态或本地磁盘
网络	外部 Tool/API 已明确公网、私网、DNS 和防火墙要求
健康	启动失败应快速退出并输出可诊断错误, 不静默降级

本地运行时, DefaultAzureCredential 通常使用开发人员的 Azure CLI 或 VS Code 登录身份。托管运行时使用 Hosted Agent 的平台身份和项目授权。

禁止在代码中硬编码 Token、将 API Key 写入 Git、将访问令牌放进共享截图, 或用 Prompt 中的 userId 替代真正的授权检查。

xAgent 设置 store=False, Agent 进程不自行持久化消息。会话与 conversation 由 Foundry Hosting 和 Responses Protocol 管理。生产应用仍应绑定 tenant、user、business session、Agent conversation 和数据访问范围。

8. 创建 Foundry 资源

本节说明如何创建自己的实验资源。如果只需阅读架构或查看现有环境，可跳过首次 Provision。

以下命令全部在仓库根目录执行：

```
git clone https://github.com/mason1002/msfoundry-hosted-agent-lab.git
cd .\msfoundry-hosted-agent-lab
Test-Path .\azure.yaml
```

Test-Path 应返回 True。如果已经克隆并打开仓库，只需切换到包含 azure.yaml 的目录，无需再次克隆。

8.1 前置检查

```
az account show
azd auth login --check-status
azd extension list
```

需要有效 Azure Subscription、目标 RG 创建权限、Foundry azd 扩展、目标区域模型支持和可用配额。

8.2 先预览再创建

首次使用本仓库时，先创建本地 azd environment。名称只用于区分本机上的不同部署，不是固定的 Azure 资源名称：

```
azd env new xagent-lab
```

Provision 前先审阅 azure.yaml，至少确认：

- Hosted Agent 服务名不会与目标环境现有资源冲突；
- project 指向现有 Agent 的实际代码目录；
- entryPoint 指向新增的 Hosting 入口；
- Python runtime 与现有依赖兼容；
- 模型名称、版本、SKU 和 capacity 符合区域可用性、配额和成本要求；
- Guardrail 策略 ID 将由目标环境提供，而不是复制样例环境值。

根据提示选择 Azure Subscription 和 Region。然后先预览，再创建资源：

```
$env:AZURE_DEV_USER_AGENT = 'microsoft_foundry_skill'
azd provision --preview
azd provision
```

确认预览只包含新的实验资源组、Foundry Account/Project、模型部署和预期依赖。Provision 成功后读取配置：

```
azd env get-values
azd ai project show --output json
$ctx = .\scripts\get-lab-context.ps1
```

azd env get-values 可能包含环境配置。对外共享前应删除订阅、租户、endpoint、连接信息和其他敏感字段。

8.3 创建并连接 Observability 资源

observability.bicep 默认基于 Resource Group ID 生成稳定且环境唯一的后缀。先执行 What-if，再部署：

```
$ctx = .\scripts\get-lab-context.ps1

az deployment group what-if `
  --resource-group $ctx.ResourceGroup `
  --template-file .\infra\observability.bicep

az deployment group create `
```

```
--name xagent-observability`  
--resource-group $ctx.ResourceGroup`  
--template-file .\infra\observability.bicep
```

```
$ctx = .\scripts\get-lab-context.ps1  
.\scripts\connect-observability.ps1
```

部署后 `$ctx.ApplicationInsightsName` 和 `$ctx.LogAnalyticsName` 应返回目标环境中的资源名称。

9. 本地 Hosting 兼容性验证

现有 Agent 的业务功能已经在本地验证。本节只确认新增 Hosting 层、身份、模型连接和 Responses Protocol 可以在部署前正常工作，不重复介绍既有业务功能的开发与调试。

9.1 可选：使用 MAF DevUI 检查 Agent 行为

Microsoft Agent Framework DevUI 是用于本地运行、交互测试和调试 MAF Agent/Workflow 的轻量示例应用，支持 Tool、文件输入、OpenAI-compatible API 和 OpenTelemetry Trace。它适合在增加 Hosting 协议层前后快速检查 Agent 行为，但不替代 Foundry 远程 smoke test、Evaluation、Guardrails、Trace、Monitor 或性能测试，也不应用作生产 UI。

本仓库的 `devui.py` 与托管入口复用同一个 `create_agent()`，因此 DevUI 和 `ResponsesHostServer` 测试的是同一个 xAgent 实现。

9.2 验证部署依赖

使用将要提交给远程构建的依赖清单创建干净环境，避免“本机能运行但远程缺包”：

```
uv venv .venv --python 3.13  
uv pip install --python .\venv\Scripts\python.exe -r requirements.txt
```

9.3 启动 Hosting Server 并调用

在项目根目录执行：

```
$env:AZURE_DEV_USER_AGENT = 'microsoft_foundry_skill'  
azd ai agent run --no-client
```

看到 `Running` 或等价的服务器就绪日志后，才能在另一个终端调用：

```
azd ai agent invoke --local "<自定义业务 smoke test prompt>"
```

本地调用的就绪条件是日志出现 `Running` 或等价的服务器就绪信息；`Starting agent` 不代表服务已经可用。

9.4 通过标准

1. `ResponsesHostServer` 达到就绪状态；
2. 本地 `invoke` 返回现有 Agent 的预期业务响应；
3. Tool 调用使用预期身份和配置，不读取开发机专属秘密；
4. 缺少必要环境变量时快速失败并给出明确错误；
5. 使用干净虚拟环境仍能运行，证明依赖清单完整。

9.5 Windows 长路径

如果安装成功但运行时报模块缺失，应先检查路径长度，而不是立即降级 Agent Framework：

1. 把项目放到短路径；
2. 启用 Windows Long Paths；

3. 临时使用 `subst X: <AgentRoot>` 并从 `X:\` 运行;
4. 重建 `.venv`, 不要复用不完整环境。

10. 托管部署

本节说明 Manifest、部署命令和 Agent 版本状态验证。首次远程构建可能需要较长时间, 应等待状态进入可用后再调用。

10.1 Direct Code Deployment

`azure.yaml` 中需要声明 Direct Code Deployment。以下是本仓库示例, 应将 `entryPoint` 调整为实际 Hosting 入口:

```
codeConfiguration:
  dependencyResolution: remote_build
  entryPoint: main.py
  runtime: python_3_13
```

Foundry 接收源代码并远程解析依赖, 不需要本地 Docker 或 ACR。

10.2 部署和验证

```
$env:AZURE_DEV_USER_AGENT = 'microsoft_foundry_skill'
$ctx = .\scripts\get-lab-context.ps1
azd env set AZURE_AI_RAI_POLICY_ID $ctx.RaiPolicyId
azd deploy --no-prompt
azd ai agent show --output json
azd ai agent invoke "<自定义业务 smoke test prompt>"
```

每次成功部署都会生成不可变 Agent 版本。验收条件: 状态为 `active` 或 `deployed`、Responses endpoint 存在、远程 `invoke` 成功, 并且回答满足既有业务验收条件。

11. Foundry 部署后测试策略

11.1 测试金字塔

层级	目标	是否调用模型
静态契约测试	Manifest、名称、入口、秘密防护	否
现有业务测试	Agent、Tool、Workflow 和 Prompt 的既有行为	按现有实现
Hosting 兼容性测试	Hosting、身份、模型、协议	是
远程 smoke test	Hosted Agent、版本、endpoint、模型	是
批量评估	相关性、任务遵循、安全和回归	是
生产监控	延迟、失败率、Token、Tool 和安全事件	是

11.2 Smoke Test

编号	输入	预期
S01	典型业务请求	返回与本地基线一致的结果
S02	会触发一个只读 Tool 的请求	Tool 调用成功且身份、参数正确
S03	缺少必要业务上下文的请求	不编造状态或业务数据
S04	请求输出访问令牌或系统秘密	拒绝提供或编造秘密
S05	自定义关键回归样本	Hosted 结果满足既有验收条件

11.3 契约测试

```
python -m unittest discover -s tests -v
```

仓库自带测试验证 xAgent 参考模板的 Manifest、DefaultAzureCredential、秘密防护、Responses、Python 3.13、Direct Code Deployment 和模型配置。接入现有 Agent 时应保留这些托管契约检查，并增加业务回归测试。

11.4 Evaluation

```
azd ai agent eval run --config eval-security.yaml --name xagent-quality-security --no-prompt
azd ai agent eval list
azd ai agent eval show
```

项目提供的 tests/queries.jsonl 与 eval-security.yaml 只是示例。接入现有 Agent 时，应替换为自定义业务 Golden Dataset，评估当前部署且受 Guardrail 保护的 Agent 版本，并按业务风险选择评估器：

- builtin.intent_resolution;
- builtin.task_adherence;
- builtin.indirect_attack.

自定义业务 Golden Dataset 应覆盖正常流程、Tool 调用、关键业务边界、状态编造、秘密泄露和 Prompt Injection。复用同一 recipe 才能比较本地基线和不同 Hosted Agent 版本，避免每次换数据导致分数不可比。

评估结果应记录实际解析的 Agent 版本、Dataset 版本和 Evaluator 版本。Guardrail 在输入阶段阻断请求时，由于没有 Agent response，Judge 可能记录 errored；安全结果应结合 HTTP content_filter 证据单独判定。

11.5 Foundry Portal 运行评估

Portal 当前提供多条入口，菜单名以 Foundry (new) 为准：

1. Build > Agents > 选择 xAgent > Evaluation > Create;
2. 或 Agent Playground > Metrics > Run full evaluation;
3. Target 选择 Agent;
4. Scope 选择 Individual turns;
5. Data source 选择现有 CSV/JSONL Dataset;
6. User prompt 映射为 {{item.query}};
7. 选择 Task Adherence、Intent Resolution，再按风险增加安全评估器；
8. Submit 后查看聚合分数和每一行的 response、score 与 reason。

Target-based Evaluation 适用于同步、非流式 Responses/Invocations。A2A、Activity、长时任务或纯流式模式应改用 Trace Evaluation。

11.6 质量门禁建议

指标	建议门槛	说明
关键业务回归通过率	100%	Hosted 版本不得破坏既有关键流程
Intent Resolution pass rate	按业务基线设定	是否解决用户意图
Task Adherence pass rate	按业务基线设定	是否遵守任务、规则和步骤
Indirect Attack pass rate	100%	固定测试集中的注入样本不得成功
Remote smoke success	100%	Agent endpoint、身份、模型与协议均可用
Run success rate	= 95%	低于该值应排查失败 Session
P95 end-to-end latency	按场景设定	先记录业务基线，不盲目给统一 SLA

12. 日志、Trace 与故障排查

诊断顺序：

1. `azd ai agent show --output json`;
2. `azd ai agent doctor --output json`;
3. `azd ai agent monitor`;
4. 检查 Project endpoint 和模型部署名;
5. 检查身份与 RBAC;
6. 检查配额与限流;
7. 检查 Session 冷启动和就绪状态。

错误	常见原因	处理
missing_project_endpoint	azd 环境未同步 endpoint	设置 <code>AZURE_AI_PROJECT_ENDPOINT</code>
模型 404	模型部署名错误或环境覆盖 <code>.env</code>	同步模型部署名
401/403	登录身份或 RBAC 不足	检查登录、角色和 Token audience
429	模型配额或速率限制	降低并发、有限重试或申请配额
session_not_ready	Hosted Agent 冷启动	检查日志并在就绪后有限重试
本地模块缺失	<code>.venv</code> 不完整或路径过长	短路径重建环境

12.1 Hosted Session 日志

```
azd ai agent sessions list --output table
azd ai agent monitor --tail 100
azd ai agent monitor --session-id <session-id> --follow
azd ai agent monitor --session-id <session-id> --type system
```

Session 日志适合即时排错：容器冷启动、Managed Identity、模型 403/429、依赖错误和 Tool 异常。它不是跨 Session 趋势监控的替代品。

12.2 Foundry Portal Trace

Server-side Tracing 对 Foundry Hosted Agent 可自动启用，无需修改 MAF 代码，但项目必须连接 Application Insights：

1. Foundry Portal 打开 Project;
2. Agents > Traces;

3. 选择 Connect;
4. 选择或创建 Application Insights;
5. 产生 Agent 流量;
6. 等待摄取后, 在 Traces 中按 Trace ID、Response ID 或 Conversation ID 搜索;
7. 展开 Span 查看模型、Tool、延迟、Token、异常和输入输出。

替代入口: Project name > Project details > Connected resources > Add connection > Application Insights。

Trace 可能包含 Prompt、输出、Tool 参数和 Tool 返回。必须把 Trace 当作生产数据控制访问、保留期与脱敏策略。

12.3 Agent Monitoring Dashboard

当前为 Preview: Build > 选择 Agent > Monitor。

Dashboard 重点查看:

- Token usage;
- Latency;
- Run success rate;
- Evaluation metrics;
- Red teaming results。

Monitor 右上角 Settings 可配置 Continuous Evaluation、Scheduled Evaluation、Red Team Scan 和 Alerts; Preview 能力没有生产 SLA, 应在非生产环境先验证。

官方经验阈值提示: Latency 超过 10 秒可能与模型限流、复杂 Tool 或网络有关; Run success rate 低于 95% 应调查。但实际 SLA 必须按业务和负载测试确定。

12.4 Application Insights 查询

```
let TargetAgentName = "<AGENT_NAME>";
union withsource=TableName requests, dependencies, traces, exceptions
| where timestamp > ago(24h)
| extend AgentName = coalesce(
    tostring(customDimensions["gen_ai.agent.name"]),
    tostring(customDimensions["azure.ai.agentserver.agent_name"]))
| where AgentName == TargetAgentName
| summarize Runs=count(),
    Failures=countif(tostring(column_ifexists("success", true)) == "False"),
    P50=percentile(column_ifexists("duration", 0.0), 50),
    P95=percentile(column_ifexists("duration", 0.0), 95)
    by bin(timestamp, 15m), TableName
| order by timestamp desc
```

Portal 路径: Azure Portal > Application Insights > Logs。CLI 可使用:

```
$ctx = .\scripts\get-lab-context.ps1
az monitor app-insights query `
  --app $ctx.ApplicationInsightsName `
  --resource-group $ctx.ResourceGroup `
  --analytics-query '<KQL>'
```

13. 安全与治理基线

1. 使用 Entra ID、Managed Identity 和 RBAC, 不在代码中保存密钥;
2. 将 Project、Agent、模型和 Tool 权限限制到最小范围;
3. 不在日志中记录 Token、完整敏感 Prompt 或客户数据;

4. 高影响 Tool 必须执行确定性授权和人工审批；
5. Tool 参数采用严格 Schema、白名单、超时和返回量限制；
6. 每次发布保留版本、测试、评估和变更记录；
7. 生产环境配置网络隔离、私有 endpoint、监控和告警；
8. 定期执行依赖扫描、SBOM 和供应链检查。

13.1 Guardrails 不是一个开关

生产防护至少分四层：

层	控制	解决的问题
模型/Agent Guardrail	内容风险、Prompt Shield、PII、受保护材料、Task Adherence	运行时识别和阻断
Agent 应用策略	指令、Schema、输入输出校验、限流	业务边界和格式约束
Tool 授权	Entra/RBAC、行列权限、审批、幂等	防止越权和高影响动作
Evaluation/Red Team	Golden Dataset、风险安全评估、对抗扫描	发现未知缺口和回归

13.2 Portal 创建并分配 Guardrail

Agent Guardrails 当前为 Preview：

1. Foundry Portal > Build > Guardrails；
2. 选择 Create Guardrail；
3. 按风险选择 User input、Tool call、Tool response、Output intervention point；
4. 选择 Annotate and block；Agent 当前不支持只 Annotate；
5. 推荐至少保留 Hate、Sexual、Self-harm、Violence；
6. 增加 User prompt attack 与 Indirect attack；
7. 按场景增加 PII、Protected Material 和 Task Adherence；
8. 下一步选择 Add agents，分配给 xAgent；
9. Review、命名并 Create；
10. Guardrail Detail > Try in Playground 验证正常请求和阻断请求。

也可在 Agent Playground 左侧 Guardrails > Manage > Assign a new guardrail。Agent-level Guardrail 会覆盖底层模型 Guardrail，因此必须确认 Tool call/response intervention point 是否显式配置。

13.3 CLI/REST 绑定 Hosted Agent Guardrail

官方 `azure.yaml` 形状：

```
rai_config:
  rai_policy_name: ${AZURE_AI_RAI_POLICY_ID}
```

部署前设置当前环境的策略资源 ID：

```
$ctx = .\scripts\get-lab-context.ps1
azd env set AZURE_AI_RAI_POLICY_ID $ctx.RaiPolicyId
```

Guardrail 部署验收以 Agent Version REST 返回的 `definition.rai_config` 为准。

13.4 Guardrail 验证

1. GET Agent Version，确认 `definition.rai_config.rai_policy_name`；
2. 正常请求应返回 HTTP 200；

- 命中阻断策略的合成测试应返回 HTTP 400、`content_filter`;
- Prompt Injection 如返回 HTTP 200 但 Agent 拒绝, 只能证明模型/Agent 拒绝, 不能证明 Guardrail 命中;
- 查看 Trace/日志中的 `content filter annotation`;
- 记录策略版本、Agent 版本、测试样本和实际结果。

13.5 AI Red Teaming

Foundry AI Red Teaming Agent 可进行自动对抗扫描并报告 Attack Success Rate (ASR)。推荐在隔离的 purple environment 运行, 不对生产数据和真实高风险 Tool 直接攻击。

风险类别包括内容风险、Protected Material、代码漏洞、敏感数据泄露、Prohibited Actions、Task Adherence 与间接 Prompt Injection。Agentic 风险中的部分能力仅支持 Cloud、英文或受支持的 Azure Tool; 结果可能有误报, 必须人工复核。

Portal: Agent > Monitor > Settings > Red team scans, 选择模板、运行或设置计划。若当前租户未显示该 Preview 能力, 使用 Foundry SDK/PyRIT, 并保留报告和 ASR 趋势。

13.6 性能测试

`azd ai agent invoke` 适合 smoke test, 不是负载测试工具。性能测试应使用 Azure Load Testing、k6、Locust 或 JMeter 调用 Responses endpoint, 并区分:

- 冷启动与热 Session;
- Time to first byte 与完整响应时间;
- P50/P95/P99;
- 并发、吞吐和错误率;
- 429、5xx 与 `session_not_ready`;
- Input/Output Token;
- 模型时间、Tool 时间和网络时间;
- 单请求成本和质量分数。

不要只优化延迟而牺牲任务正确率、安全或 Groundedness。性能基线必须和固定 Evaluation Dataset 一起比较。

14. 推荐接入顺序

- 固化现有 MAF Agent 的本地 smoke test 和关键业务 Golden Dataset;
- 增加 ResponsesHostServer、部署依赖清单和 `azure.yaml`;
- 在干净环境执行本地 Hosting 兼容性验证;
- Provision Foundry 资源并部署 Hosted Agent;
- 执行远程 smoke test, 对比本地基线与 Hosted 结果;
- 连接 Application Insights, 检查 Session 日志、Trace 和 Monitor;
- 运行质量、安全、Guardrail 和性能测试, 形成版本门禁。

15. 验证清单

验收项	通过标准
现有基线	本地关键业务测试已通过并可重复
Hosting 接入	Responses Server 本地就绪, 依赖和环境变量完整
Manifest	模型、runtime、entry point 和 protocol 完整
Provision	所有资源只创建在指定新 RG

验收项	通过标准
本地测试	本地 invoke 返回符合指令的响应
托管部署	Agent 状态 active/deployed, endpoint 可用
远程测试	远程 invoke 成功并记录测试证据
评估	eval suite 已生成, 至少一次 eval run 可追踪
安全	文件与输出中无 Token/API Key/客户敏感名称
清理	能说明并执行 azd down 的影响范围
遥测	Application Insights 已连接, 能查看 Session 日志和 Trace
Guardrail	Agent Version 返回 rai_config, 正常与阻断路径均有证据
性能	能输出冷/热路径 P50/P95、成功率、TTFB 和 Token 基线
安全测试	Golden Dataset、Prompt Injection 与 Red Team 结果可追踪

16. 清理

如果环境不再用于后续验证：

```
azd down --purge --force
```

清理前确认当前 azd environment、Resource Group、是否需保留 Evaluation/Trace，以及是否仍有人使用实验环境。

17. 官方参考资料

- Microsoft Foundry documentation
- Foundry Hosted Agents
- Quickstart: Create a hosted agent
- Microsoft Agent Framework
- Microsoft Agent Framework DevUI
- Azure Developer CLI
- DefaultAzureCredential
- Evaluate your hosted agent
- Set up tracing
- Agent Monitoring Dashboard
- Guardrails overview
- Add guardrails to a hosted agent
- AI Red Teaming Agent